



SOC Incident Response Report

Joomla Web Server Compromise and Website Defacement

Prepared by: Mahmoud Hassan Mahmoud

Prepared by	Mahmoud Hassan Mahmoud
Role	SOC Analyst / Incident Investigator
Scenario	Splunk BOTS v1 / TryHackMe - simulated enterprise (Wayne Enterprises, imreallynotbatman.com)
Affected asset	Web server 192.168.250.70 (Joomla CMS)
Scenario date	10 August 2016
Data sources	Splunk index botsv1: stream:http, suricata, fortigate_utm, xmlwineventlog (Sysmon)
IR phase	Detection and Analysis



Figure 1. Defaced home page of imreallynotbatman.com.

Incident Overview

This report documents a hands-on incident response investigation performed on the Splunk Boss of the SOC (BOTS) v1 data set, a simulated enterprise security data set. In the scenario, the fictional organization Wayne Enterprises finds that its public website, <http://www.imreallynotbatman.com>, has been defaced with the message "YOUR SITE HAS BEEN DEFACED". The objective is to determine how the attacker gained access, what was done on the server, and which infrastructure was used.

Network, firewall, IDS and endpoint telemetry was already collected in Splunk, so the work is a log-driven reconstruction of the attack. Each finding is tied to a Splunk search and a screenshot of its result. The investigation belongs to the **Detection and Analysis** phase; detection ideas and hardening actions are given in Sections 9 and 10.



1. Executive Summary

On **10 August 2016** the Joomla CMS running on 192.168.250.70 was compromised and the site was defaced. The attacker identified the CMS with an Acunetix scan from **40.80.148.42**, brute-forced the Joomla administrator login from **23.22.63.114** and authenticated as **admin** with the password **batman**. Two minutes later the same credential was used from the scanner address. Using the administrator panel, the attacker uploaded a PHP web shell (`agent.php`) and a file manager (`exTplorer_2.1.5.zip`), ran commands through the shell as `NT AUTHORITY\IUSR`, and executed an uploaded binary, `3791.exe`. The server then fetched an image from `prankglassinebracket.jumpingcrab.com:1337`, and at 22:20:33 image files were renamed on the web root to produce the defacement.

Attacker infrastructure: 40.80.148.42 (scanning, exploitation, file upload) and 23.22.63.114 (brute force and command-and-control hosting).

2. Incident Scope

The scope is defined from the HTTP stream data: which host received the traffic, who talked to it, and which of those clients belong to the incident.

2.1 Victim identification

A count of destination addresses in the HTTP stream data shows that 20,275 of 23,936 events, or 96.6%, are directed at 192.168.250.70. That host is the web server and the focus of this investigation (Figure 2). Counting the clients that talk to it gives three sources: 40.80.148.42 with 18,632 events (91.9%), 23.22.63.114 with 1,429 (7.0%) and 192.168.2.50 with 214 (1.1%) (Figure 3).

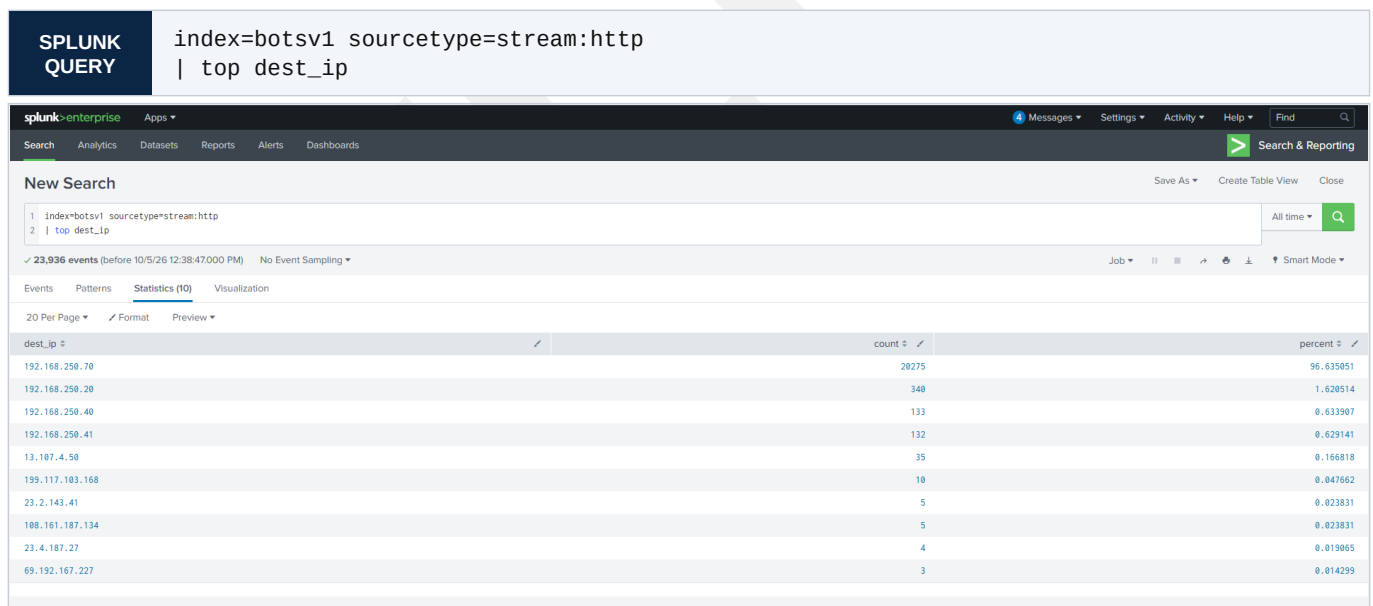


Figure 2. Top destination IPs in HTTP traffic. 192.168.250.70 receives 96.6% of all events.



Figure 3. Client IPs reaching the web server. Two external addresses account for 98.9% of requests.

2.2 Scope check: 192.168.2.50

The third client, 192.168.2.50, was checked before being excluded. Its 818 HTTP events use a single Internet Explorer 8 user agent and touch generic login and management paths such as /login, /admin/login.jsp and /officescan/default.htm; none of the top URIs are Joomla paths (Figure 4). Its Suricata alerts are limited to five signatures (RDP reset DoS, unusual traffic on ports 445 and 135, a malformed DNS response and an IIS integer-overflow signature) (Figure 5). All five were first and last seen on **24 August 2016 between 16:33 and 16:37**, fourteen days after the defacement (Figure 6). The host is therefore treated as unrelated to this incident.

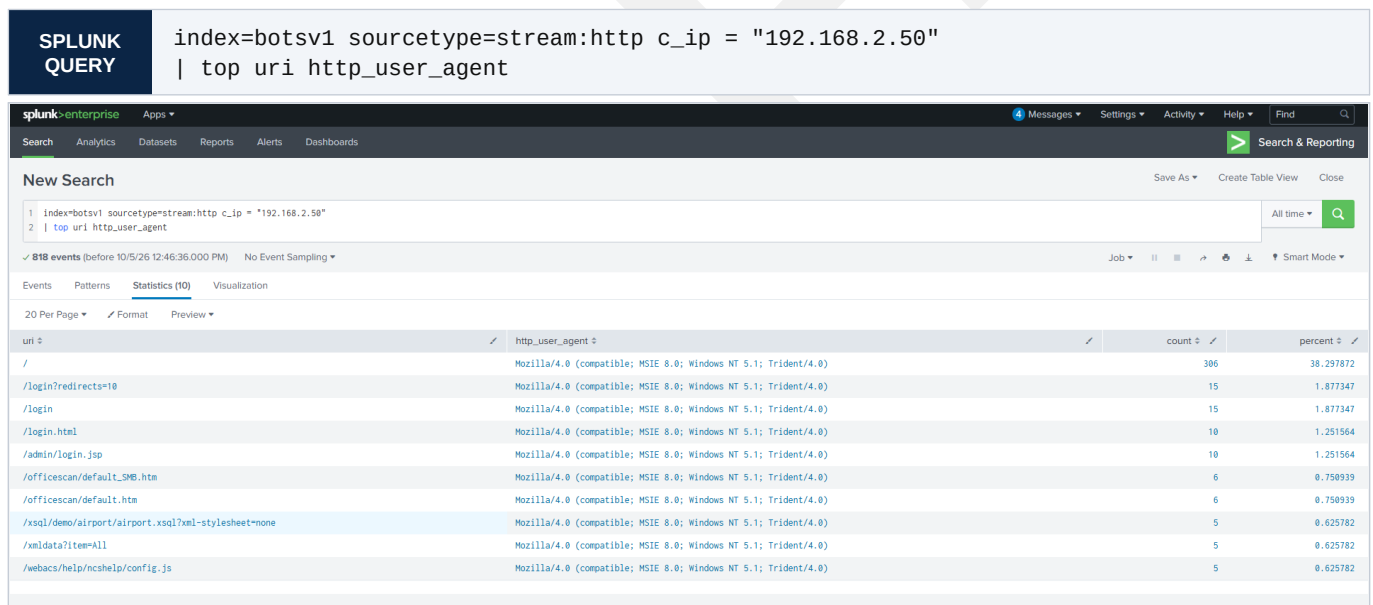


Figure 4. HTTP activity of 192.168.2.50: generic login/admin URIs, no Joomla paths.

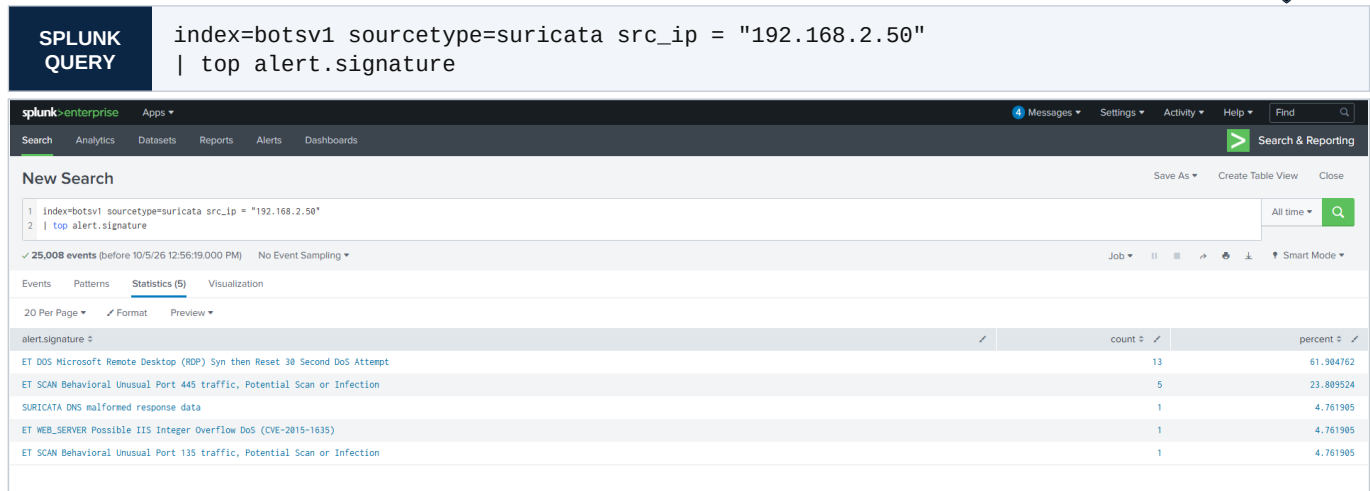


Figure 5. Suricata signatures raised for 192.168.2.50.

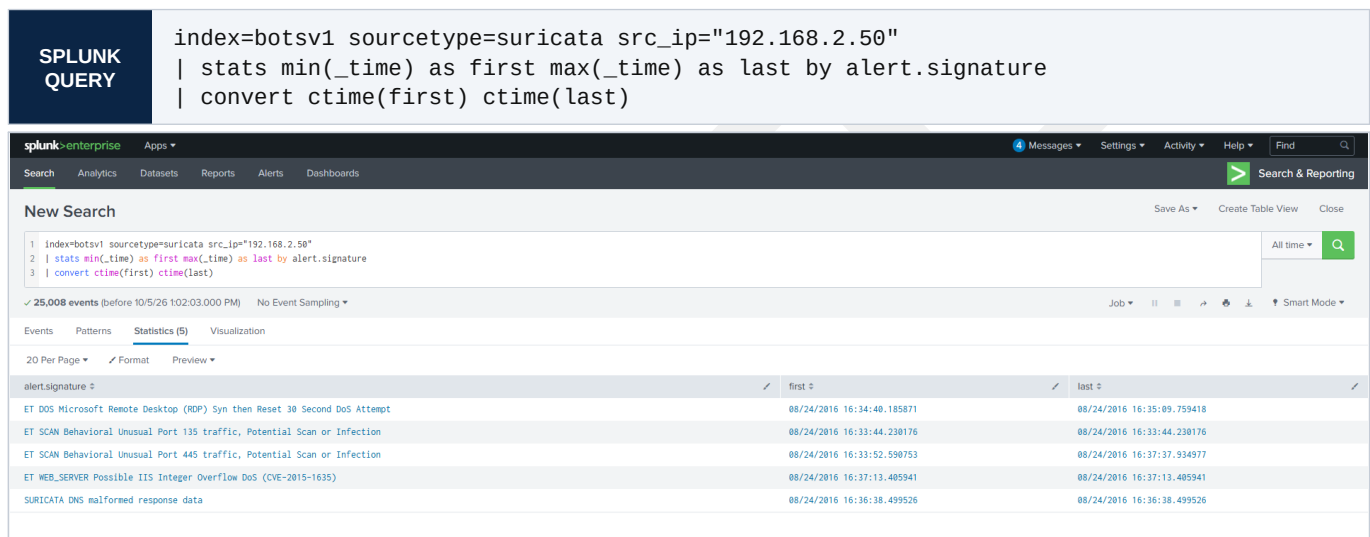


Figure 6. First and last occurrence per signature: all on 08/24/2016, outside the incident window.

3. Attack Chain

The activity follows the stages of the Cyber Kill Chain. Section 4 walks through each stage with the supporting Splunk searches.

Stage	What happened	Key evidence
Reconnaissance	Acunetix scan of the web server from 40.80.148.42; Joomla identified	Suricata alerts, /joomla/administrator/ URIs
Initial access	Brute force of the Joomla admin login from 23.22.63.114; login as admin:batman	Python-urllib/2.7, 412 distinct passwords
Installation	agent.php web shell and eXtplorer uploaded via the admin panel	Multipart POSTs from 40.80.148.42
Execution	Commands run as IUSR through php-cgi.exe; 3791.exe executed	Sysmon process creation
Command and control	Web server requests a file from prankglassinebracket.jumpingcrab.com:1337	Fortigate outbound logs
Actions on objectives	Image files renamed on the web root; site defaced at 22:20:33	Sysmon: move 2.jpeg imnotbatman.jpg



4. Technical Investigation

4.1 Reconnaissance

40.80.148.42 generated 17,802 Suricata events. The signature breakdown is typical of an automated web vulnerability scanner: 103 cross-site scripting alerts on script tags in the URI, 48 on onmouseover=, 41 XXE attempts, 65 SQL injection alerts (33 SELECT FROM and 32 sleep-based), 36 CVE-2014-6271 (Shellshock) alerts and 45 hits of ET SCAN Acunetix Version 6 (Free Edition) Scan Detected (Figure 7).



Figure 7. Suricata signatures from 40.80.148.42. The Acunetix scanner signature identifies the tool.

Filtering all Suricata signatures for the string CVE returns 39 events across four rules. The CVE-2014-6271 pair accounts for 36 of them (18 "Attempt" and 18 "Attempt in Headers"); the others are CVE-2015-1635 (2) and CVE-2012-3152 (1) (Figure 8).

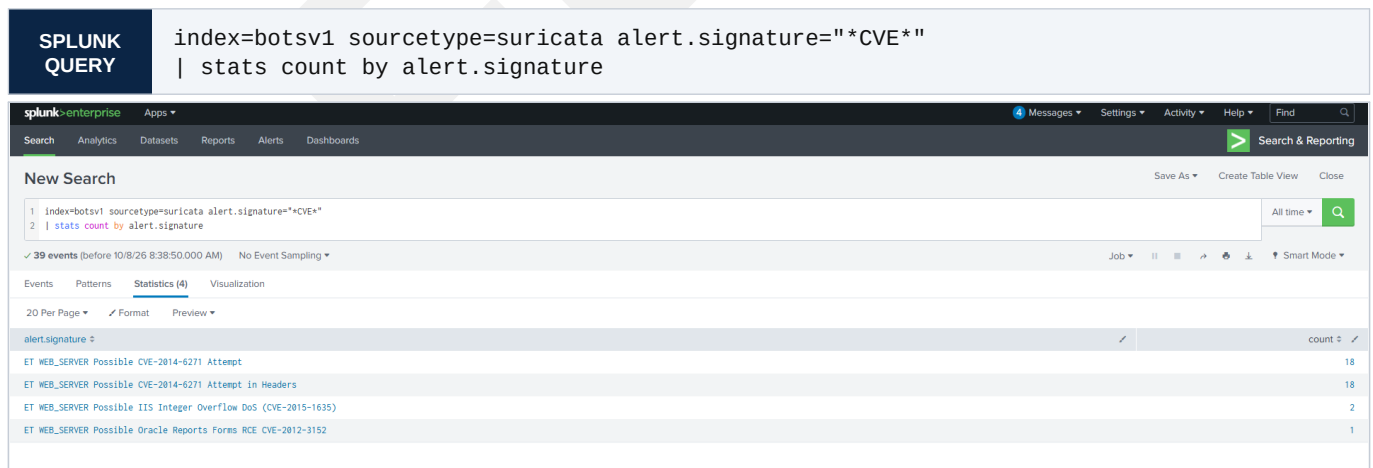


Figure 8. CVE-tagged Suricata alerts. CVE-2014-6271 is the attack-attempt CVE in this data set.

The CMS was identified from the request paths the scanner hit on the server. Of 1,298 events matching *administrator*, 46 distinct URIs include /joomla/administrator/ and Joomla component paths, alongside Acunetix probes such as ofc_upload_image.php?name=acunetix_test against many component directories (Figure 9). The web application is **Joomla**.

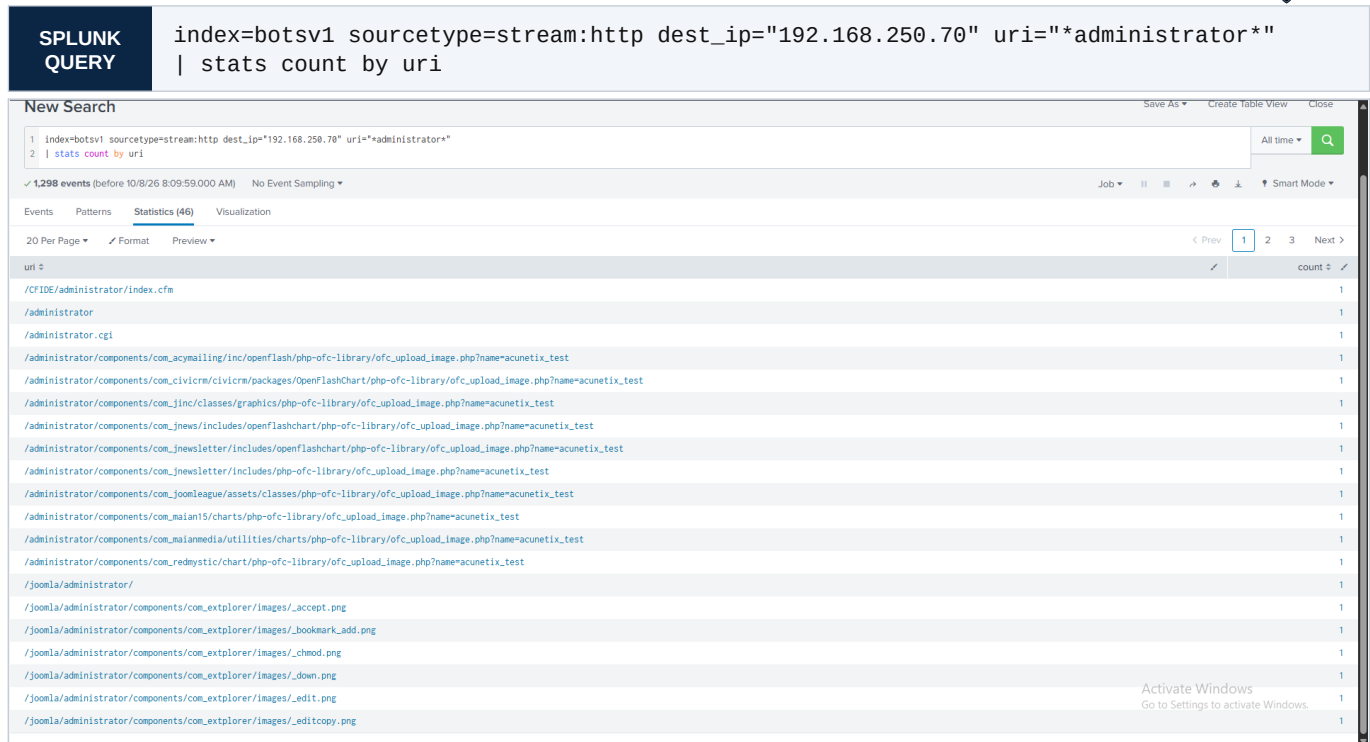


Figure 9. Administrator-path URIs on the victim: Joomla paths and Acunetix probe strings (acunetix_test).

4.2 Initial Access

23.22.63.114 produced 1,430 HTTP events. The dominant pattern is 1,235 requests (86.4%) to /joomla/administrator/index.php with the user agent Python-urllib/2.7, which identifies a scripted client rather than a browser. The same address also requested /joomla/agent.php with a rotating set of browser user-agent strings, two requests each (Figure 10).

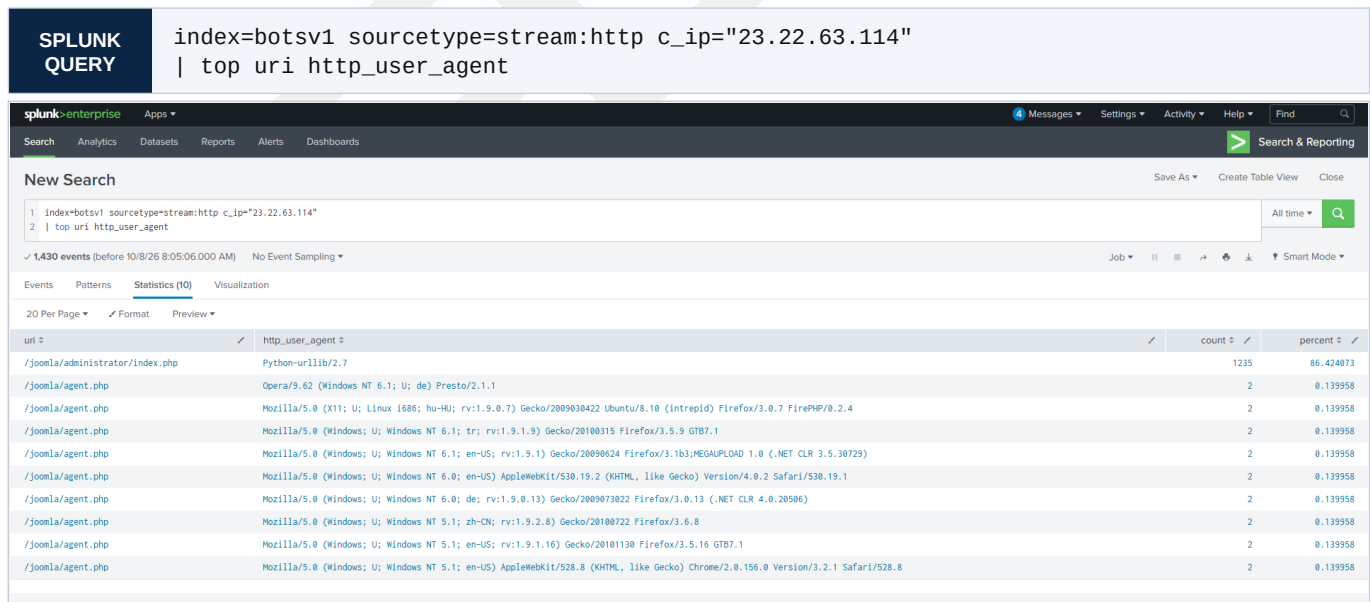


Figure 10. Requests from 23.22.63.114: login endpoint with Python-urllib/2.7, followed by agent.php requests.

Extracting the submitted passwd field from the login POSTs returns 425 events and 412 distinct password values. Each value appears once except **batman**, which appears twice (Figure 11). That is the pattern of a wordlist attack in which the correct password is eventually submitted.

SPLUNK
QUERY

```
index=botsv1 sourcetype=stream:http uri="/joomla/administrator/index.php"
http_method=POST
| rex field=form_data "passwd=(?<password>[^\&]+)"
| stats count by password
| sort - count
```

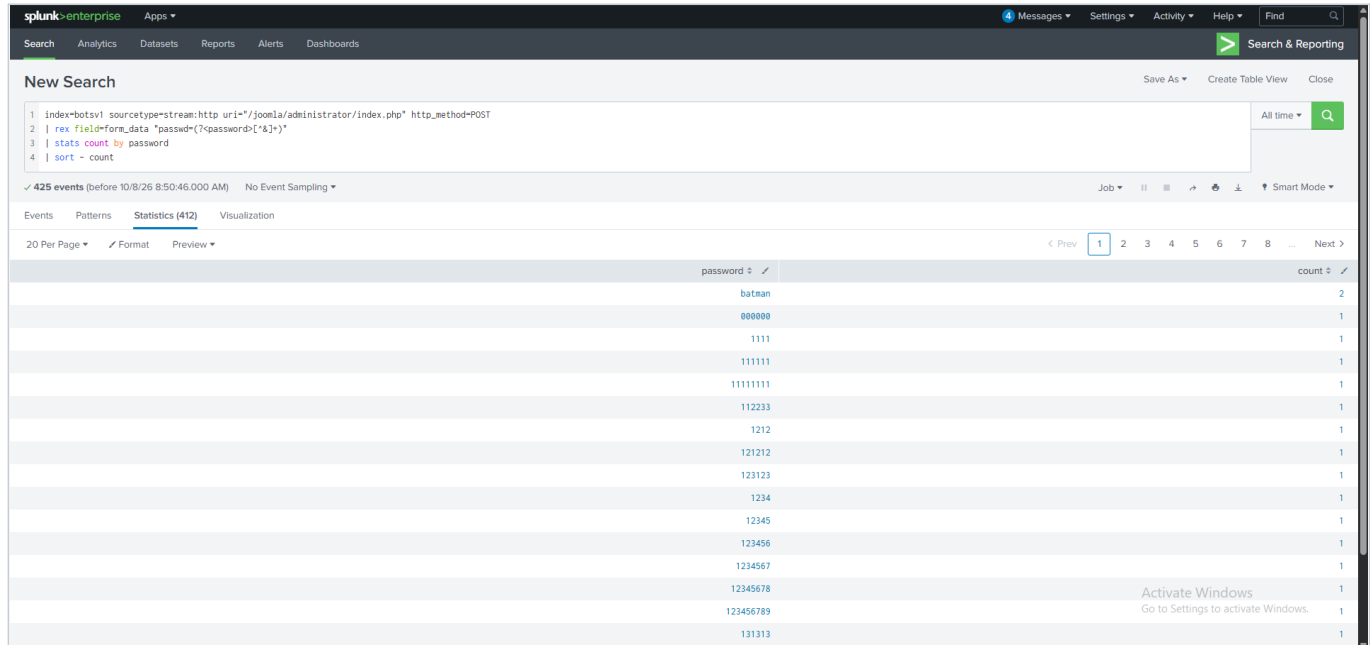


Figure 11. Passwords submitted to the Joomla login. "batman" is the only value seen twice.

Searching the POST bodies for the password shows the two successful submissions: from **23.22.63.114 at 21:46:33** and from **40.80.148.42 at 21:48:05** (Figure 12). The attacker therefore reused the cracked credential from the scanning address about ninety seconds after the brute-force host obtained it.

SPLUNK
QUERY

```
index=botsv1 sourcetype=stream:http uri="/joomla/administrator/index.php"
http_method=POST form_data="*batman*"
| table _time c_ip
| sort _time
```

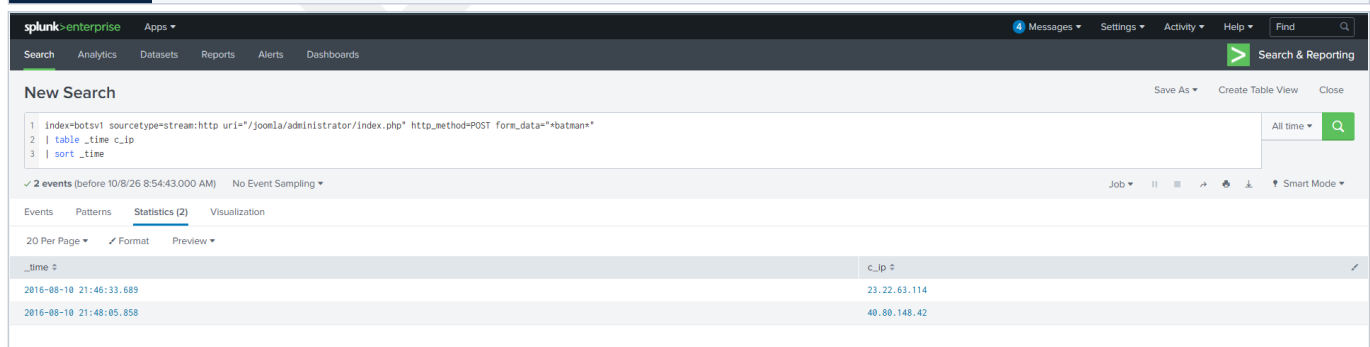


Figure 12. POSTs containing the password "batman": one from each attacker IP, 92 seconds apart.

4.3 Installation and Execution

Multipart POST requests carrying a file name show two uploads, both from **40.80.148.42**: agent . php and eXtplorer_2.1.5.zip (Figure 13). The first is a PHP web shell; the second is the eXtplorer file manager, installed as a Joomla component (the com_extplorer image paths also appear in Figure 9).



SPLUNK QUERY

```
index=botsv1 sourcetype=stream:http http_method=POST
| where isnotnull(part_filename)
| stats count by part_filename c_ip
```

part_filename	c_ip	count
agent.php	40.80.148.42	1
exTplorer_2.1.5.zip	40.80.148.42	1

Figure 13. Files uploaded through the Joomla administrator: agent.php and exTplorer_2.1.5.zip.

Sysmon process-creation events whose parent is php-cgi.exe record what the web shell executed: 17 commands, all under NT AUTHORITY\IUSR, the IIS anonymous account (Figure 14). The sequence starts at 21:55:22 with an echo of a numeric marker, continues with dir, ls and ifconfig (the last two are not Windows commands, which suggests an operator working from Unix habits), and at **21:56:18** runs 3791.exe.

SPLUNK QUERY

```
index=botsv1 sourcetype=xmlwineventlog EventCode=1 ParentImage="*php-cgi.exe*"
| table _time CommandLine User
```

_time	CommandLine	User
2016-08-10 21:56:18	cmd.exe /c "3791.exe 2&1"	NT AUTHORITY\IUSR
2016-08-10 21:55:33	cmd.exe /c "ifconfig 2&1"	NT AUTHORITY\IUSR
2016-08-10 21:55:26	cmd.exe /c "ls 2&1"	NT AUTHORITY\IUSR
2016-08-10 21:55:24	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 21:55:22	cmd.exe /c "echo 24365"	NT AUTHORITY\IUSR
2016-08-10 22:05:42	cmd.exe /c "echo 63055"	NT AUTHORITY\IUSR
2016-08-10 22:21:34	cmd.exe /c "exit 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:21:31	cmd.exe /c "exit 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:20:33	cmd.exe /c "move 2.jpeg immotbatman.jpg 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:20:13	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:20:10	cmd.exe /c "move ..\1.jpeg 2.jpeg 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:19:48	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:19:22	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:19:14	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:16:47	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:15:52	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR
2016-08-10 22:13:26	cmd.exe /c "dir 2&1"	NT AUTHORITY\IUSR

Figure 14. Commands spawned by php-cgi.exe, all as NT AUTHORITY\IUSR. The "2>&1" redirect is added by the web shell.

The executable was located at C:\inetpub\wwwroot\joomla\3791.exe, inside the web root, so it was written there through the web shell or file manager. Sysmon logged 69 events for it, the first rows stamped 21:56:18 and 21:56:19 (Figure 15). Its MD5 is AAE3F5A29935E6ABCC2C2754D12A9AF0.

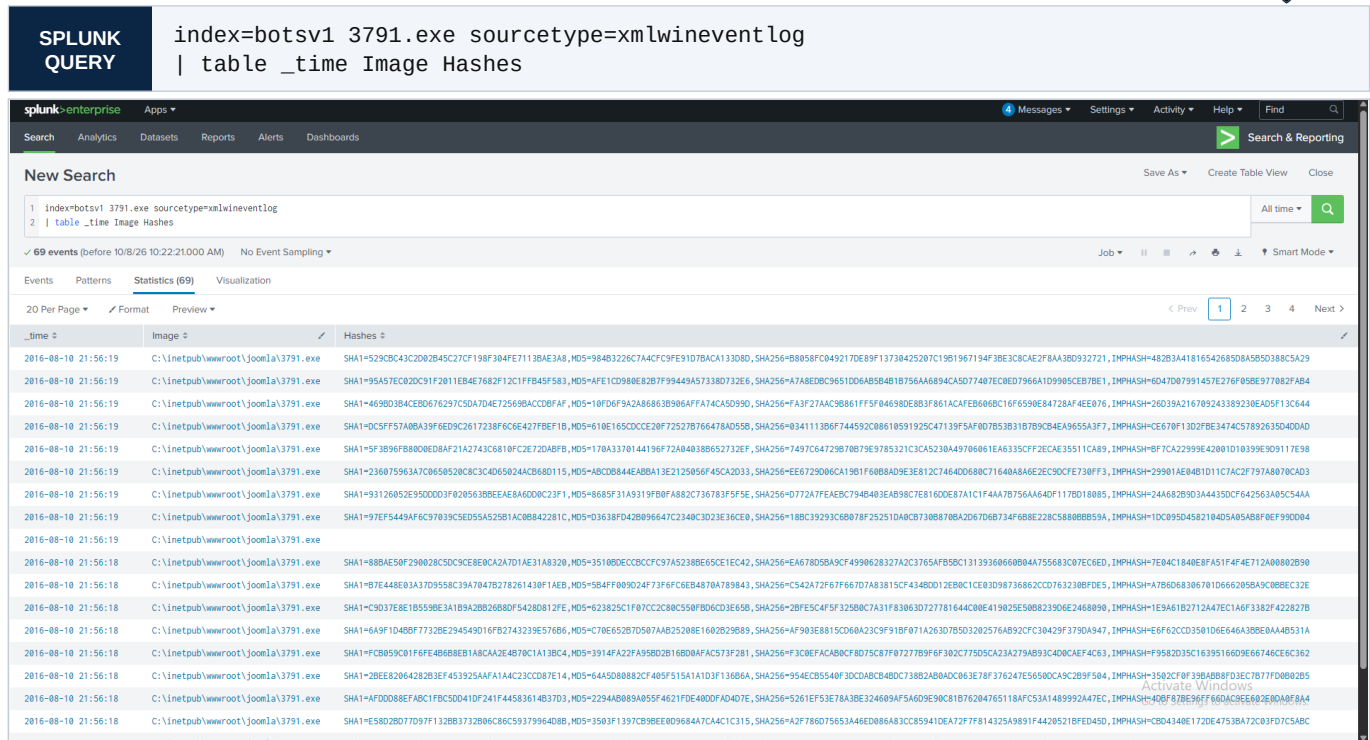


Figure 15. Sysmon events referencing 3791.exe in the Joomla web root (69 events).

4.4 Command and Control

Outbound firewall logs from the web server show only two destinations: 108.161.187.134 on port 80 (6 events) and **23.22.63.114 on port 1337** (3 events) (Figure 16). A web server initiating connections to a non-standard port on the brute-force host is the key indicator here.

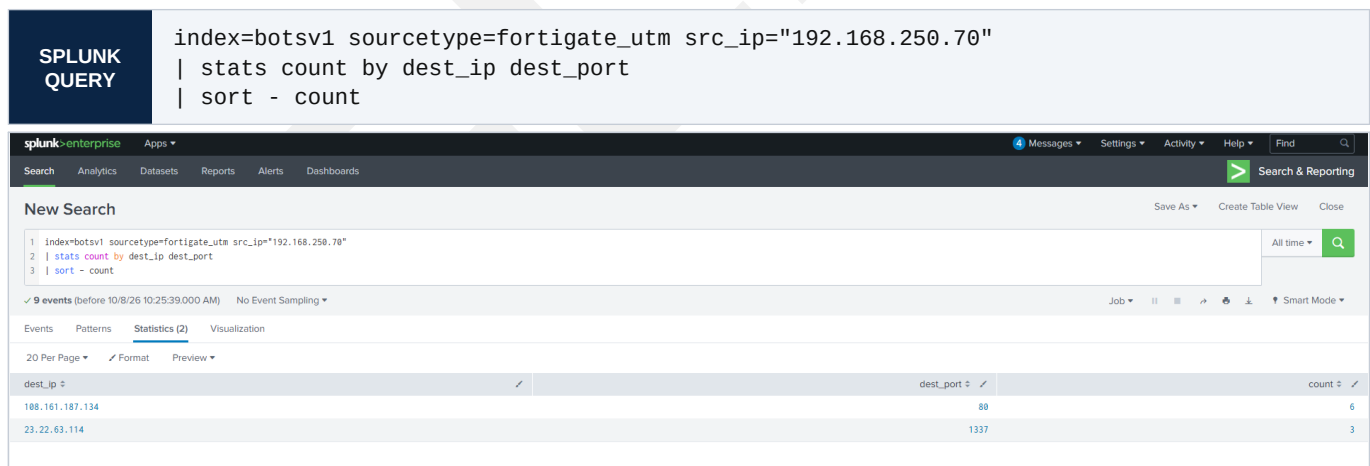


Figure 16. Destinations contacted by the web server. Port 1337 to 23.22.63.114 stands out.

The three connections were requests for the same file from the dynamic-DNS name `prankglassinebracket.jumpingcrab.com:1337: /poisonivy-is-coming-for-you-batman.jpeg` at 22:06:21, 22:13:46 and 22:19:10 (Figure 17).



SPLUNK QUERY

```
index=botsv1 sourcetype=fortigate_utm src_ip="192.168.250.70" dest_ip="23.22.63.114"
| table _time url
```

_time	url
2016-08-10 22:19:10	pranglassinebracket-jumpingcrab.com:1337/poisonivy-is-coming-for-you-batman.jpeg
2016-08-10 22:13:46	pranglassinebracket-jumpingcrab.com:1337/poisonivy-is-coming-for-you-batman.jpeg
2016-08-10 22:06:21	pranglassinebracket-jumpingcrab.com:1337/poisonivy-is-coming-for-you-batman.jpeg

Figure 17. Requests from the web server to the attacker domain on port 1337.

The same search against 40.80.148.42 returns nothing (Figure 18): the server never connected out to the scanning address, so that IP is inbound-only and 23.22.63.114 is the single command-and-control host.

SPLUNK QUERY

```
index=botsv1 sourcetype=fortigate_utm src_ip="192.168.250.70" dest_ip="40.80.148.42"
| stats count by dest_port url
```

No results found.

Figure 18. No outbound connections from the victim to 40.80.148.42 (0 events).

4.5 Actions on Objectives

The web-shell command log in Figure 14 also shows the defacement itself. At 22:20:10 the command `move .\1.jpeg 2.jpeg` was run, and at **22:20:33** `move 2.jpeg imnotbatman.jpg`, both through `cmd.exe` under `php-cgi.exe`. This follows the third request for `poisonivy-is-coming-for-you-batman.jpeg` at 22:19:10 and is consistent with the attacker swapping the site's image files for attacker-supplied content. The result is the page shown in Figure 1.



5. Evidence and Splunk Queries

All searches ran against index botsv1 over All time. Each query is printed directly above its screenshot in Sections 2 and 4; the index below lists them in one place.

Figure	Purpose	Sourcetype
Figure 2	Victim host: top destination IPs	stream:http
Figure 3	Clients reaching the victim	stream:http
Figure 4	192.168.2.50: HTTP activity	stream:http
Figure 5	192.168.2.50: IDS signatures	suricata
Figure 6	192.168.2.50: alert timing (24 Aug)	suricata
Figure 7	Scanner signatures from 40.80.148.42	suricata
Figure 8	CVE-tagged alerts	suricata
Figure 9	Joomla administrator URIs	stream:http
Figure 10	23.22.63.114 requests and user agents	stream:http
Figure 11	Passwords submitted to Joomla login	stream:http
Figure 12	Successful logins with batman	stream:http
Figure 13	Uploaded files	stream:http
Figure 14	Commands run by the web shell	xmlwineventlog
Figure 15	3791.exe process events	xmlwineventlog
Figure 16	Outbound destinations of the web server	fortigate_utm
Figure 17	Requests to the C2 domain	fortigate_utm
Figure 18	Connections to 40.80.148.42 (none)	fortigate_utm

6. Indicators of Compromise

Type	Value	Description
IP	40.80.148.42	Acunetix scanning, Shellshock/SQLi probing, file upload, repeat login
IP	23.22.63.114	Joomla brute force, C2 host (port 1337)
IP	192.168.250.70	Victim web server
Domain	prankglassinebracket.jumpingcrab.com	Dynamic-DNS C2 domain
URL	prankglassinebracket.jumpingcrab.com:1337/poisonivy-is-coming-for-you-batman.jpeg	File fetched by the victim
Email	lillian.rose@po1s0n1vy.com	Contact associated with the P01s0n1vy APT
File	agent.php	PHP web shell (Joomla web root)
File	eXtplorer_2.1.5.zip	File manager uploaded via the administrator panel
File	3791.exe (aka ab.exe)	Malware executed from C:\inetpub\wwwroot\joomla\
MD5	AAE3F5A29935E6ABCC2C2754D12A9AF0	Hash of 3791.exe



Type	Value	Description
Compromised Credential	admin / batman (lab credential)	Joomla administrator account from the simulated data set
User agent	Python-urllib/2.7	Brute-force client
CVE	CVE-2014-6271	Shellshock, attempted by the scanner

7. Attack Timeline (10 August 2016)

Time	Event	Source
21:36:45	Acunetix scan from 40.80.148.42 begins	Suricata
21:45:08	Brute force against /joomla/administrator/ begins (23.22.63.114)	stream:http
21:46:33	Successful login with admin:batman from 23.22.63.114	stream:http
21:48:05	Same credential used from 40.80.148.42	stream:http
21:50:31	agent.php uploaded	stream:http
21:55:22	First web-shell command executed (echo)	Sysmon
21:56:18	3791.exe executed	Sysmon
22:06:21	First request to prankglassinebracket.jumpingcrab.com:1337	Fortigate
22:13:46	Second request to the C2 domain	Fortigate
22:19:10	Third request to the C2 domain	Fortigate
22:20:10	move ..\1.jpeg 2.jpeg	Sysmon
22:20:33	move 2.jpeg imnotbatman.jpg - website defaced	Sysmon

8. MITRE ATT&CK Mapping

Tactic	Technique ID	Technique	Observed evidence
Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning	Acunetix scan, 17,802 Suricata events
Initial Access	T1110.001	Brute Force: Password Guessing	412 distinct passwords, Python-urllib/2.7
Execution	T1059.003	Windows Command Shell	cmd.exe spawned by php-cgi.exe
Persistence	T1505.003	Server Software Component: Web Shell	agent.php in the Joomla web root
Defense Evasion	T1036.005	Masquerading	Payloads named after legitimate files/images
Command and Control	T1071.001	Application Layer Protocol: Web Protocols	HTTP requests to port 1337
Impact	T1491.001	Defacement: Internal Defacement	Image files renamed on the web root

Reconnaissance (T1595.002) is listed as observed activity against the web server before access was obtained; the remaining techniques were observed after the attacker had access.



9. Detection Opportunities

Each behaviour seen in this incident can be turned into a detection. The logic below is based on the fields used in the investigation.

Detection	Data source	Logic	ATT&CK
Brute-force Joomla login	stream:http	Many POSTs to /joomla/administrator/index.php from one source in a short window; count distinct passwd values	T1110.001
Credential reuse	stream:http	Successful admin login from a new IP shortly after a high-volume failed-login source	T1078
Web shell execution	Sysmon (EventCode 1)	ParentImage php-cgi.exe spawning cmd.exe	T1505.003
Suspicious web file	Sysmon / file logs	New .php or .exe file created under C:\inetpub\wwwroot	T1505.003
Suspicious egress	fortigate_utm	Web server connecting to an external host on an uncommon port (e.g. 1337) or a dynamic-DNS domain	T1071.001
Website defacement	File / Sysmon	Unexpected rename or move of web-root image files	T1491.001
Scanner activity	suricata	Acunetix or Shellshock signatures from one external IP above a threshold	T1595.002

10. Recommendations

- Protect the Joomla administrator.** Restrict /administrator to management IP ranges and enforce MFA. The brute force submitted 412 different passwords with no lockout, and the account password was a dictionary word.
- Add account lockout and rate limiting.** Block a source after a small number of failed logins; a scripted client sent 1,235 requests to one URI.
- Patch Joomla and its components.** Update the core and all extensions, remove unused ones, and review the extensions list for eXtplorer.
- Deploy a WAF in front of the site.** Enable rules for scanner user agents, Shellshock headers and SQL injection; the scanner triggered all three families.
- Block extension installation from the web.** Disable uploads through com_installer where not needed and make the web root read-only for the IIS identity.
- Run IIS with least privilege.** Prevent php-cgi.exe from spawning cmd.exe; IUSR executed discovery commands and an uploaded binary.
- Filter egress.** Deny outbound traffic from the web server except required destinations; block TCP/1337 and dynamic-DNS domains such as jumpingcrab.com.
- Alert on the observed behaviours.** Create Splunk detections for php-cgi.exe as a parent of cmd.exe, for file creation under the web root, and for the Python-urllib/2.7 login pattern.
- Hunt and clean.** Search all web servers for agent.php, eXtplorer and 3791.exe, rotate the Joomla credentials and restore the site from a known-good backup.



11. Investigation Findings and Lessons Learned

What the investigation established

- The initial access vector was a brute-force attack on the Joomla administrator login, which succeeded with a weak, dictionary-based password.
- Brute-force activity was correlated with successful authentication: the password appears in the POST data and in two logins, one from each attacker IP.
- Web-shell execution was traced through Sysmon: php-cgi.exe spawned cmd.exe under NT AUTHORITY\IUSR, ending with the execution of 3791.exe.
- Command and control was identified from firewall logs: the web server requested a file from prankglassinebracket.jumpingcrab.com on port 1337.
- Indicators of compromise were extracted (Section 6) and the behaviour was mapped to MITRE ATT&CK (Section 8).
- Detection and hardening improvements were proposed (Sections 9 and 10).

Lessons learned

- No single log source showed the whole attack. Linking HTTP, IDS, Sysmon and firewall data was needed to build the chain.
- Process lineage is a strong indicator: a web server process launching a command shell is rarely legitimate.
- Outbound logs exposed the C2 channel even though the attack began inbound; egress visibility on servers matters.
- Attacks can come from several addresses. The scanner IP also logged in with the stolen credential, so blocking one IP is not enough.

END OF REPORT